Threat Narrative: Business Email Compromise & Wire Fraud

Adversary TTP: Executive Impersonation / Social Engineering Manipulation

Incident Chronology

An advanced Business Email Compromise (BEC) attempt targeted the corporate treasury department. The attacker spoofed the Chief Executive Officer's identity to pressure finance managers into executing an urgent, out-of-band wire transfer for an alleged confidential acquisition.

Transcript of Spoofed Communication

FROM: Richard Vance TO: accounts-payable@enterprise.example.org SUBJECT: CONFIDENTIAL: Project Titan Settlement — Immediate Wire Required

Body Text

'Sarah, I am currently in closed-door board negotiations regarding our strategic acquisition of Horizon Analytics. Due to strict NDA stipulations, you must NOT discuss this transaction with anyone, including the CFO or legal team. We have reached a binding agreement requiring an immediate earnest deposit of $480,000 to escrow account details below: Bank: Apex Commercial Escrow (Offshore Clearing) Routing Number: 021000089 Account Number: 8839-4412-9901 Beneficiary: Horizon Holdings Ltd. Please bypass standard dual-authorization protocols just this once to prevent the deal from falling through. Send the wire confirmation receipt directly to my private assistant address: exec-ops@exec-confidential-board[.]example[.]org. I am relying on your discretion. Richard Vance, CEO'

Behavioral & Technical Indicators

This communication triggers multiple behavioral social engineering indicators:

1. **Out-of-Band Process Bypass**: Requesting the recipient to bypass dual-authorization financial controls.

2. **Artificial Secrecy Mandate**: Instructing the victim not to consult standard internal stakeholders.

3. **Spoofed Executive Sender**: Registering typo-squatted domain `exec-confidential-board[.]example[.]org`.

Indicator	Type	Threat Assessment
exec-confidential-board[.]example[.]org	Domain	Impersonation Infrastructure
exec-ops@exec-confidential-board[.]example[.]org	Email	Adversary Exfiltration Mailbox
ceo-office@exec-confidential-board[.]example[.]org	Email	Executive Spoof Sender

Correlated ATT&CK; Framework Mapping

• **T1566.001 (Phishing: Spearphishing Attachment / Communication)**

• **T1656 (Impersonation)**: Deceptive masquerading as senior enterprise leadership.

Defensive Controls & Financial Safeguards

Controls required to eliminate wire fraud risks:

• Mandatory phone call back verification using verified intranet contact directory for any wire exceeding $10,000.

• Enforce DMARC `p=reject` policy on all corporate domains.

• Flag incoming emails containing external sender warnings and executive display name mismatches.

Severity Assessment: HIGH (8.2 / 10.0)